

Quy định điểm quá trình

- Điểm QT = $0.75 \times \text{Điểm thi GK} + 0.25 \times \text{Điểm bài tập về nhà} + \text{Chuyên cần}$
- Bài tập về nhà:
 - Trắc nghiệm trên hệ thống MOOC
 - Được làm lại nhiều lần
 - Điểm bài tập về nhà = $10 \times \text{Tỉ lệ số câu đúng}$

Điểm chuyên cần

- Điểm chuyên cần gồm 2 thành phần:
Điểm chuyên cần = Điểm kỳ A + Điểm kỳ B
 - Nếu Điểm chuyên cần > 1 : Điểm chuyên cần = +1
 - Nếu Điểm chuyên cần < -2 : Điểm chuyên cần = -2
 - Tổng số buổi không đạt = 4: Điểm chuyên cần = -1
- Điểm bài trắc nghiệm $> 50\%$ được coi là đạt
- Điểm thành phần:
 - Đạt tất cả các bài trắc nghiệm: +1
 - Không đạt 1-2 bài: 0
 - Không đạt 3-4 bài: -1
 - Không đạt ≥ 5 bài: -2

Chúng ta học gì?

- Suy nghĩ về hệ thống thông tin như một kẻ tấn công
 - Xác định mối đe dọa và điểm yếu của hệ thống
- Làm cách nào để thực hiện một số kỹ thuật tấn công
 - Khai thác lỗ hổng phần mềm
- Suy nghĩ về hệ thống như người thiết kế giải pháp AT-ANTT
 - Cách thức ngăn chặn và giảm thiểu tấn công
 - Hiểu và ứng dụng các nguyên lý AT-ANTT
 - Hiểu và ứng dụng các cơ chế, công cụ AT-ANTT



ĐẠI HỌC BÁCH KHOA HÀ NỘI
HANOI UNIVERSITY OF SCIENCE AND TECHNOLOGY

7

7

Tài liệu tham khảo

- [1] TS. Nguyễn Khanh Văn (2015). *Giáo trình Cơ Sở An Toàn Thông Tin*. Nhà xuất bản Bách Khoa Hà nội.
- [2] Matt Bishop (2004). *Introduction to Computer Security*. Addison-Wesley
- [3] Tài liệu đọc thêm theo từng bài



ĐẠI HỌC BÁCH KHOA HÀ NỘI
HANOI UNIVERSITY OF SCIENCE AND TECHNOLOGY

8

8



11

1. Mở đầu

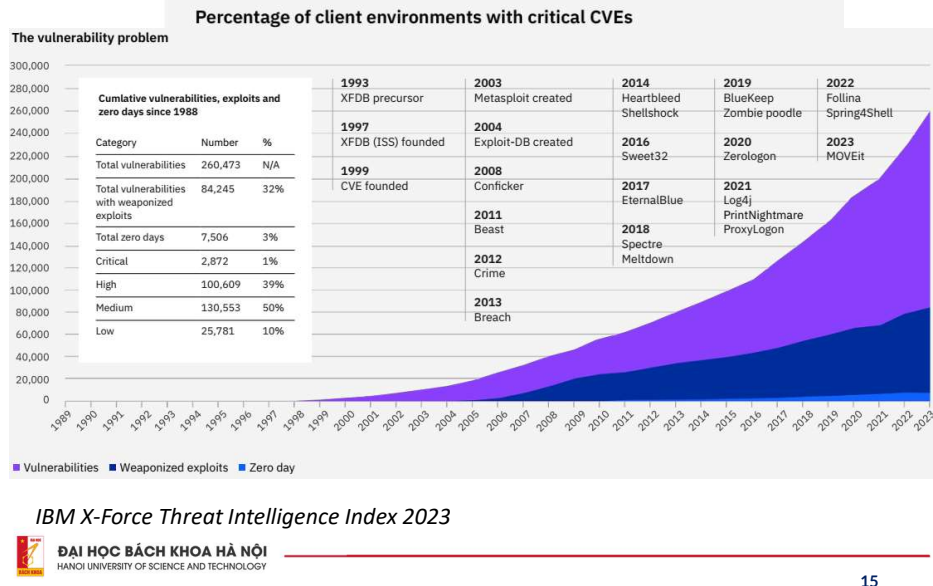
- Báo cáo về an toàn an ninh thông tin:
 - IBM X-Force Threat Intelligence Index 2024
 - Verizon 2024 Data Breach Investigations Report
 - Microsoft Digital Defense Report 2024
 - Viettel Threat Intelligence 2024

 **ĐẠI HỌC BÁCH KHOA HÀ NỘI**
HANOI UNIVERSITY OF SCIENCE AND TECHNOLOGY

12

12

Tấn công AT-ANTT là phổ biến



15

An toàn an ninh thông tin là gì?

Bảo vệ tài nguyên hệ thống thông tin trước các hành vi gây tổn hại

- Tài nguyên hệ thống:
 - Phần cứng: máy tính, đường truyền, thiết bị mạng...
 - Phần mềm
 - Dữ liệu
 - Người dùng
- Các hành vi gây tổn hại: phần lớn là các hành vi tấn công cố ý
 - Tấn công vật lý: tấn công vào phần cứng
 - Tấn công logic: sử dụng các chương trình phá hoại để can thiệp vào quá trình xử lý và truyền dữ liệu

16

Nguy cơ với an toàn thân thể

Former CIA director: 'We kill people based on metadata'

12 May, 2014 18:27 / Updated 5 years ago

The Telegraph News Politics Sport Business Money Opinion Tech Life Style Tri

UK news World news Royals Health Defence Science Education Innov

News Science
Hackers could kill patients by attacking their pacemakers, warns Royal Academy of Engineering

REUTERS

Business Markets World Politics TV More

TECHNOLOGY NEWS OCTOBER 4, 2016 / 4:05 PM / 3 YEARS AGO

J&J warns diabetic patients: Insulin pump vulnerable to hacking

Jim Finkle

6 MIN READ



Former National Security Agency (NSA) and Central Intelligence Agency (CIA) Director Michael Hayden (Reuters/Larry Downing) © Reuters

2805



ĐẠI HỌC BÁCH KHOA HÀ NỘI
HANOI UNIVERSITY OF SCIENCE AND TECHNOLOGY

19

19

Đánh cắp thông tin cá nhân

LAO ĐỘNG

Google Translate

CHÍNH SÁCH VIỆT NAM

LAO ĐỘNG

LAO ĐỘNG

LAO ĐỘNG

British Airways faces record \$230 million fine over data theft

Paul Sandle

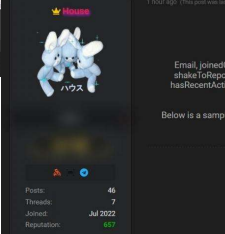
3 MIN READ

f

Vụ rò rỉ hơn 163 triệu tài khoản Zing ID: Chủ các tài khoản nên thay đổi mật khẩu

Duolingo (2.6 Million Entries) Scrape

by House - Tuesday, January 24, 2023 at 02:18 AM



Personal data for 533 million Facebook users leaks on the web

It had been circulating privately since January.



Jon Fingas

Reporter

Sun, Apr 4, 2021 · 1 min read

2 triệu dữ liệu ngân hàng nghi bị hacker đánh cắp

g: Cảnh báo bảo mật camera

Anh Vũ ★★★★★
ngvut@gmail.com

Mai Hà ★★★★★
maihua2@gmail.com

10:47 - 22/11/2019

THÀNH NIÊN ONLINE

Một Ngân hàng TMCP vừa bị các hacker "điểm danh" khi tuyên bố đang nằm trong tay 2 triệu dữ liệu khách hàng.

09:43 - 29/12/2019

THÀNH NIÊN ONLINE



ĐẠI HỌC BÁCH KHOA HÀ NỘI
HANOI UNIVERSITY OF SCIENCE AND TECHNOLOGY

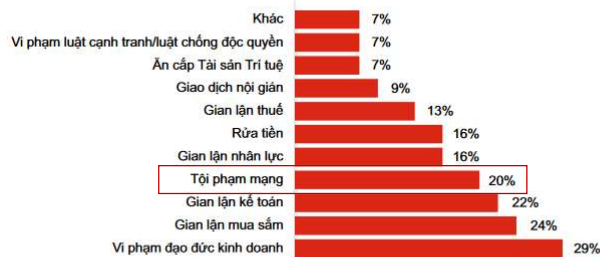
20

20

Tác động tới nền kinh tế

Các loại hình gian lận xảy ra trong 24 tháng qua

Báo cáo khảo sát Tội phạm kinh tế tại Việt Nam năm 2018 – PWC Vietnam



KINH TẾ

Năm 2017, tội phạm mạng gây thiệt hại cho kinh tế Việt Nam 12.700 tỷ đồng

Trung tâm Tin tức VTV24 - Thứ ba, ngày 27/03/2018 09:36 GMT+7

ĐẠI HỌC BÁCH KHOA HÀ NỘI
HANOI UNIVERSITY OF SCIENCE AND TECHNOLOGY

TIN LIÊN QUAN

Thiệt hại khoảng 20 nghìn tỷ đồng do virus máy tính

ANTD.VN - Theo ước tính của Tập đoàn công nghệ Bkav, năm 2019, thiệt hại do virus máy tính gây ra đối với người dùng Việt Nam đã lên tới 20.892 tỷ đồng (902 triệu USD), vượt xa con số 14.900 tỷ đồng của năm 2018.

23

Tác động tới nền kinh tế



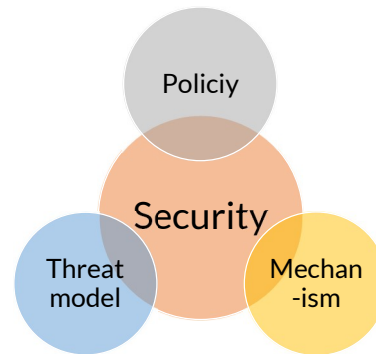
There's Nowhere to Hide from the Economics of Cybercrime

Cybercrime cost the global economy as much as \$600 billion in 2017. New technologies and connections mean new threats to some countries and new opportunities to others. Cybercrime impacts nearly every location on the globe. The first step to fighting it is understanding its scope and reach. McAfee, an industry leader in device-to-cloud security, teamed up with the Center for Strategic and International Studies (CSIS) to study the global economic impact of cybercrime. The costs vary by location, income levels, cybersecurity maturity, and other variables.

24

AT-ANTT là gì?

- Bao gồm các khía cạnh:
 - Chính sách
 - Mô hình đe dọa
 - Cơ chế AT-ANTT
- Chính sách AT-ANTT (security policy): tuyên bố về các mục tiêu/yêu cầu AT-ANTT của hệ thống
 - Chủ thể thực hiện
 - Hành vi phải thực hiện/được phép/không được phép
 - Tài nguyên



Mục tiêu: Mô hình CIA

- Confidentiality (Bí mật): tài nguyên chỉ được tiếp cận bởi các bên được cấp quyền
- Integrity (Toàn vẹn): tài nguyên chỉ được sửa đổi bởi các bên được cấp quyền
- Availability (Sẵn sàng): tài nguyên sẵn có để đáp ứng yêu cầu
 - Thời gian đáp ứng chấp nhận được
 - Tài nguyên được định vị trí rõ ràng
 - Khả năng chịu lỗi
 - Dễ dàng sử dụng
 - Đồng bộ khi đáp ứng yêu cầu

Một số cơ chế AT-ANTT(tiếp)

- Bảo vệ vật lý (Physical protection)
- Mật mã học (Cryptography)
- Định danh (Identification)
- Xác thực (Authentication)
- Ủy quyền (Authorization)
- Nhật ký (Logging)
- Kiểm toán(Auditting)
- Sao lưu và khôi phục (Backup and Recovery)
- Dự phòng (Redundancy)
- Giả lập, ngụy trang (Deception)
- Gây nhiễu, ngẫu nhiên(randomness)

Mô hình đe dọa

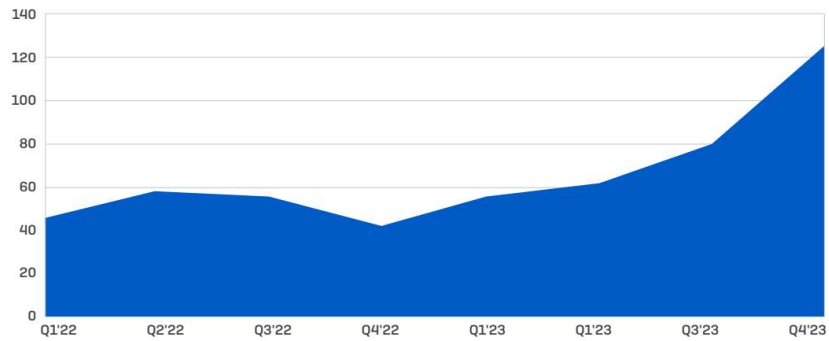
- Threat Model: mô tả những mối đe dọa kẻ tấn công có thể gây ra cho hệ thống và hậu quả
 - Cái gì cần bảo vệ?
 - Ai có thể tấn công vào hệ thống? Chúng có gì?
 - Hệ thống có thể bị tấn công như thế nào?
- Độ rủi ro (Risk): khả năng xảy ra các sự cố làm mất an toàn an ninh thông tin và thiệt hại của chúng cho hệ thống

$$\text{Risk} = \text{Threat} \times \text{Impact}$$

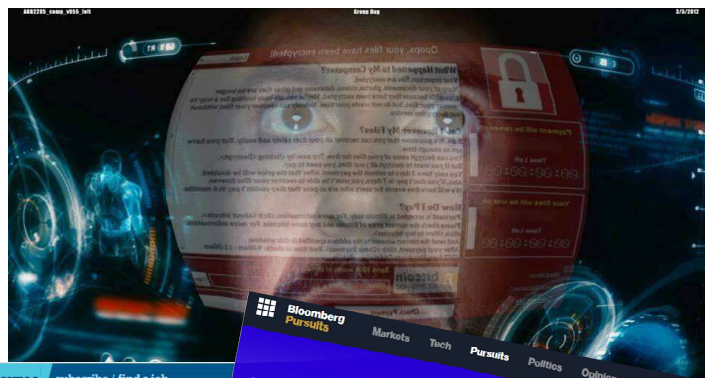
- Lỗ hổng (Vulnerability): là những điểm yếu trong hệ thống có thể bị khai thác, lợi dụng để gây tổn hại cho hệ thống
 - <https://www.cvedetails.com/>
 - Tầm soát lỗ hổng định kỳ là một trong những giải pháp phòng chống tấn công

Ransomware(2024)

Remote ransomware incidents, 2022-2023



WannaCry (05/2017)



become a supporter subscribe / find a job

news / opinion / sport / arts /

tech / world / UK / science / cities / global

Malware

WannaCry: hackers withdraw £108,000 or bitcoin ransom

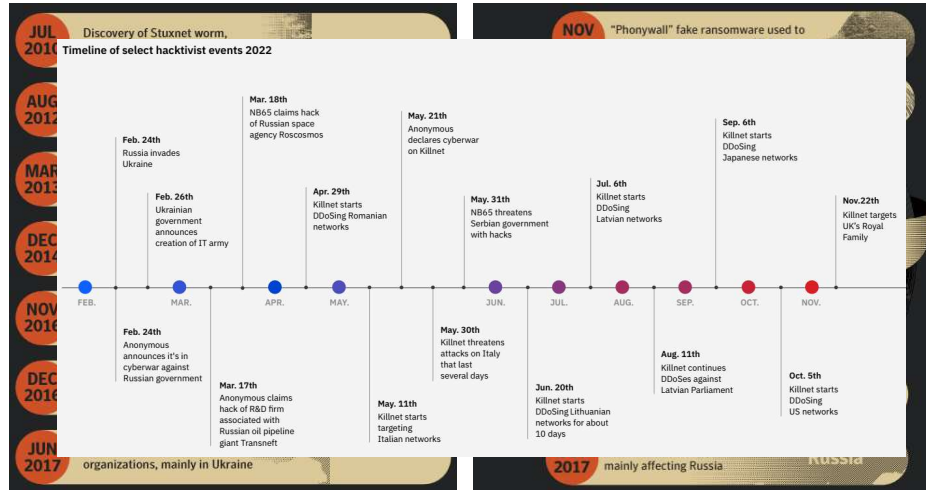
Next WannaCry Cyber Attack Could Cost Insurers \$2.5 Billion

Bloomberg Pursuits Markets Tech Pursuits Politics Opinion Businessweek

Subscribe to Businessweek Sign in

Động cơ tấn công

• Mục đích chính trị

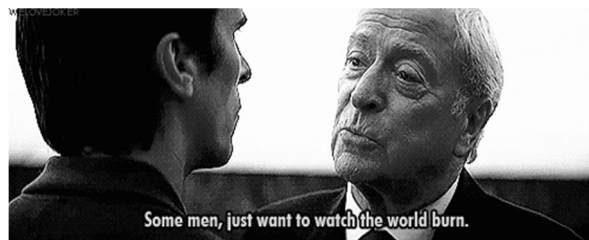


Động cơ tấn công

• Đùa cợt



• Thú vui phá hoại

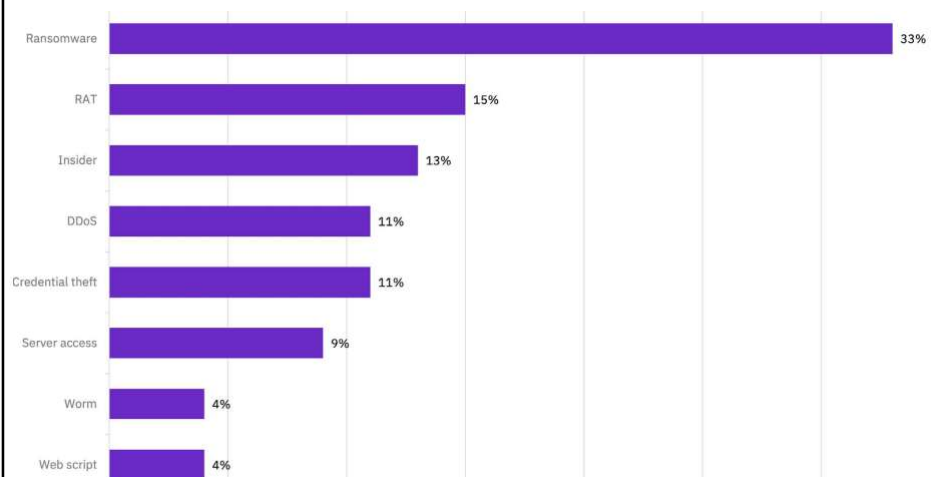


Phân loại tấn công

- Tấn công thụ động(passive attack) và tấn công chủ động(active attack)
 - Tấn công thụ động: không can thiệp, làm thay đổi hoạt động của hệ thống
 - Tấn công chủ động: can thiệp, làm thay đổi hoạt động của hệ thống
- Tấn công có chủ đích(targeted attack/APT attack) và tấn công không có chủ đích(non-targeted attack)
 - Tấn công có chủ đích: mục tiêu đã xác định
 - Tấn công không có chủ đích: mục tiêu bất kỳ
- Tấn công bên trong và tấn công bên ngoài

43

Một số dạng tấn công phổ biến



IBM X-Force Threat Intelligence Index 2021

44

Quy trình xây dựng

4 giai đoạn:

- Phân tích yêu cầu
 - Xây dựng chính sách AT-ANTT
 - Xác định các tình huống lạm quyền
 - Thiết kế
 - Xây dựng mô hình nguy cơ
 - Thiết kế hướng bảo mật
 - Triển khai
 - Duyệt mã nguồn (Code review)
 - Kiểm thử và bảo trì
 - Kiểm thử theo nguy cơ ATBM
 - Kiểm thử xâm nhập
-
- Các giai đoạn được thực hiện tuần tự
 - Luôn có sự phản hồi của giai đoạn sau tới giai đoạn trước
 - Chia để trị

Quy trình xây dựng

- Xây dựng chính sách: có thể mô tả ban đầu bằng ngôn ngữ tự nhiên:
 - Hành vi phải thực hiện/được phép/ không được phép
 - Chủ thể của hành vi
 - Đối tượng hành vi tác động tới
 - Điều kiện
- Xây dựng các tình huống lạm quyền minh họa cho sự xâm phạm chính sách
- Chính sách AT-ANTT phải phù hợp với quy định luật pháp

Hiểu biết về mô hình đe dọa với hệ thống

- Ví dụ: Phần lớn két sắt chỉ có khả năng chống cháy
 - Bảo vệ tài sản ở nhiệt độ bên trong $< 177^{\circ}\text{C}$ trong thời gian tối thiểu 30 phút khi nhiệt độ bên ngoài $> 1000^{\circ}\text{C}$
 - Bảo vệ tài sản ở nhiệt độ bên trong $< 55^{\circ}\text{C}$ trong thời gian tối thiểu 30 phút khi nhiệt độ bên ngoài $> 1000^{\circ}\text{C}$
- Chọn mua két sắt loại nào?



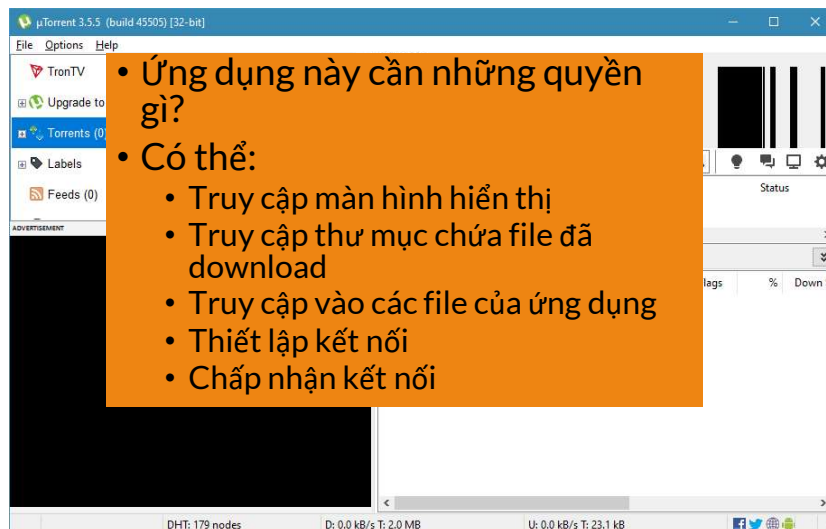
Quy trình xây dựng

- Thiết kế các thành phần theo mô hình nguy cơ: lựa chọn cơ chế AT-ANTT
 - Ngăn chặn: Loại bỏ hoàn toàn nguy cơ
 - Giảm thiểu
 - Chấp nhận nguy cơ
 - Chuyển nhượng rủi ro
- Triển khai
 - Chú ý: đào tạo người dùng
- Vận hành và bảo trì:
 - Chú ý: cần liên tục giám sát hệ thống

Một số nguyên tắc(tiếp)

- Tối thiểu hóa quyền (Least privilege): không cấp quyền nhiều hơn những gì mà đối tượng cần để hoàn thành nhiệm vụ.

Tối thiểu hóa quyền – Ví dụ



The screenshot shows the uTorrent 3.5.5 application window. An orange overlay box is positioned in the center, containing the following text:

- Ứng dụng này cần những quyền gì?
- Có thể:
 - Truy cập màn hình hiển thị
 - Truy cập thư mục chứa file đã download
 - Truy cập vào các file của ứng dụng
 - Thiết lập kết nối
 - Chấp nhận kết nối

Chia sẻ trách nhiệm (Separation of responsibility)

- Quyền chỉ được thực thi khi có yêu cầu đồng thời từ nhiều bên



ĐẠI HỌC BÁCH KHOA HÀ NỘI
HANOI UNIVERSITY OF SCIENCE AND TECHNOLOGY

59

59

Một số nguyên tắc (tiếp)

- Chia sẻ tối thiểu (Least common mechanism): Tài nguyên cần được chia sẻ tới ít bên nhất có thể
- Dễ hiểu, dễ sử dụng cho người dùng (Usable):
 - Người dùng sẽ tuân thủ cơ chế an toàn bảo mật hay quyết định phá vỡ nó?
 - Nếu bạn không làm hệ thống dễ sử dụng và an toàn thì người dùng sẽ làm cho nó dễ sử dụng và không an toàn.

→ KISS: Keep It Simple, Sir!

→ Complexity is the enemy



ĐẠI HỌC BÁCH KHOA HÀ NỘI
HANOI UNIVERSITY OF SCIENCE AND TECHNOLOGY

60

60

Dễ hiểu cho người dùng – Ví dụ

• Trên IE8

Source	 There is a problem with this website's security certificate.
Risk	The security certificate presented by this website was not issued by a trusted certificate authority. Security certificate problems may indicate an attempt to fool you or intercept any data you send to the server.
Choices	We recommend that you close this webpage and do not continue to this website. ☒ Click here to close this webpage. ☐ Continue to this website (not recommended). More information
Process	• If you arrived at this page by clicking a link, check the website address in the address bar to be sure that it is the address you were expecting. • When going to a website with an address such as https://example.com, try adding the 'www' to the address, https://www.example.com. • If you choose to ignore this error and continue, do not enter private information into the website. For more information, see "Certificate Errors" in Internet Explorer Help.

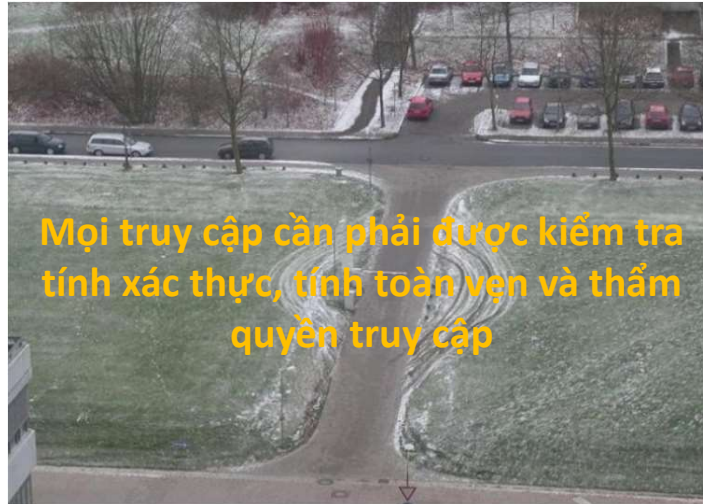
Dễ hiểu cho người dùng – Ví dụ

• Google Chrome

Risk	 Your connection is not private
Explanation	Attackers might be trying to steal your information from expired.badssl.com (for example, passwords, messages, or credit cards). Learn more NET::ERR_CERT_DATE_INVALID ☒ Help improve Safe Browsing by sending some system information and page content to Google. Privacy policy
Choices	Advanced Back to safety

Một số nguyên tắc(tiếp)

- Kiểm soát tất cả truy cập(Complete mediation)



Kiểm tra tất cả truy cập

- Time Of Check To Time Of Use: TOCTTOU
 - Lỗi hổng tranh đua điều kiện (Race Condition)

```
procedure withdrawal(w)
// contact central server to get balance
1. let b := balance
2. if b < w, abort
// balance could have decreased at this point
// contact server to set balance
3. set balance := b - w
4. dispense $w to user
```

Điều gì xảy ra nếu thủ tục trên được gọi trên các luồng thực thi song song?

Một số nguyên tắc (tiếp)

- Security is process, not service
- AT-ANTT là quá trình, không phải dịch vụ
 - Thiết kế AT-ANTT ngay từ đầu

71

4. Cơ sở tính toán được tin cậy (Trusted Computing Base)

72

Trusting trust?

- “Reflections on Trusting Trust” – Ken. Thompson

- Nếu tin tưởng vào các chương trình thực thi?
 - Ví dụ: #login
 - RedHat có đáng tin không?
 - Mật khẩu của người dùng có được gửi trái phép tới đâu không?
- Nếu không tin tưởng
 - Kiểm tra mã nguồn hoặc tự viết lại mã nguồn
 - Vấn đề đã được giải quyết chưa?

- Chúng ta tin cậy vào cái gì?

- Có thể lấy rất nhiều ví dụ khác...



TCB

- Thiết kế AT-ANTT cho hệ thống luôn phải chỉ ra được các thành phần trong TCB
- Yêu cầu với TCB:
 - Không thể vòng tránh(unbypassable)
 - Chống sửa đổi (Tamper-resistant)
 - Có thể thẩm tra (Verifiable)
- Thiết kế TCB sao cho đơn giản là rất quan trọng
 - Simple = Small